

BEFORE Placeholder

AFTER

Contract Clauses — Incident Notification & Communications (Clause Library)

Document classification: Internal template (for contracts)

Template owner: Legal Counsel (terms) / Security Incident Lead (requirements) / DPO/Privacy Officer (privacy)

Version: 0.1

Effective date: _____

Note: Select clauses proportionate to tier and service scope. Use generic role titles. "Material incident" should be defined in the main agreement or security schedule.

A) Definitions (optional but helpful)

A1 — Security incident "Security Incident" means any actual or reasonably suspected unauthorised access, disclosure, alteration, loss, or compromise of Customer data, Customer systems, or the security of the Services.

A2 — Material incident A "Material Security Incident" is a Security Incident that:

- affects or is reasonably likely to affect Customer data or Customer tenancy, and/or
 - impacts integrity of the Services used by Customer, and/or
 - materially impacts availability of a critical service, and/or
 - triggers legal/regulatory/customer notification obligations.
-

B) Tier 1 (Critical) — recommended default clauses

B1 — Notification timeframe (Critical default) Supplier shall notify Customer of any Material Security Incident affecting the Services and/or Customer data:

- within **24 hours** of confirmation, and
- without undue delay where the incident is reasonably suspected to materially affect the Customer (even if full details are not yet available).

B2 — Notification channels Supplier shall provide notifications via the agreed channel(s) and maintain 24x7 contact details for Severity 1 incidents.

B3 — Minimum notification content Initial notification shall include, as available:

- incident summary and current status
- start time (earliest known) and detection time (with time zone)
- affected systems/environments/regions
- whether Customer scope is impacted (confirmed/unknown) and expected time to confirm
- data types potentially affected (e.g., personal data, financial data, authentication secrets)
- containment actions taken and immediate next steps
- recommended Customer actions (e.g., credential/token rotation, access restriction)
- next update time and update cadence

B4 — Ongoing updates For Severity 1 incidents impacting Customer scope, Supplier shall provide updates at least **daily** (or more frequently as agreed) until containment and stabilisation.

B5 — Cooperation and evidence Supplier shall cooperate with Customer's investigation and response, including providing relevant logs/evidence, reasonable technical assistance, and responses to information requests in a timely manner.

B6 — Post-incident report (RCA) For any Material Security Incident, Supplier shall provide a post-incident report (RCA) within **10 business days** (or an agreed timeframe), including:

- timeline of key events
- root cause analysis
- customer impact assessment

- corrective actions and target dates
 - measures implemented to prevent recurrence
-

C) Tier 2 (Important) — proportionate clauses

C1 — Notification timeframe (Important default) Supplier shall notify Customer of any Material Security Incident affecting the Services and/or Customer data within **48 hours** of confirmation.

C2 — Minimum notification content Supplier shall provide an initial summary, affected service scope, containment actions taken, and the time of the next update.

C3 — Cooperation Supplier shall provide reasonable cooperation, including relevant evidence and updates until closure.

C4 — RCA For material incidents, Supplier shall provide an RCA summary with corrective actions and dates.

D) Tier 3 (Low) — lightweight clauses

D1 — Reasonable notification Supplier shall notify Customer of any security incident affecting the Services that may materially impact Customer data within a reasonable timeframe.

D2 — Cooperation Supplier shall provide reasonable cooperation to support Customer enquiries regarding potential impact.

E) Personal data breach (privacy-led) add-on

Use when personal data is processed/stored/accessed.

E1 — Personal data breach support Where an incident involves personal data, Supplier shall provide information reasonably required to support Customer's breach assessment and any notifications, including:

- categories of personal data and data subjects involved
- approximate volume (if known)
- processing locations and any sub-processors involved
- mitigation actions taken and recommended next steps

(Align with DPA terms and DPO/Privacy Officer requirements.)

F) Supplier sub-processor incident flow-up (add-on)

F1 — Sub-processor incident notification Supplier shall ensure that sub-processors promptly notify Supplier of incidents affecting the Services and/or Customer data, and Supplier shall notify Customer in accordance with this incident notification clause.

G) Service outage communications (add-on for critical services)

G1 — Outage notification For outages materially impacting service availability, Supplier shall notify Customer without undue delay and provide:

- current status and estimated time to restore
 - workaround guidance where available
 - update cadence until service restoration
-

H) Practical fallback positions (if supplier pushes back)

If supplier rejects 24-hour notification (Critical):

- fallback 1: **48 hours** + "without undue delay for suspected material impact"
- fallback 2: keep 24/48-hour window but specify it as "from detection of a material incident affecting Customer scope"
- fallback 3: strengthen cooperation/evidence rights and require daily updates + RCA + incident-driven evidence clauses

If supplier rejects daily updates:

- require "updates at agreed cadence appropriate to severity, not less than every 48 hours for Severity 1".

If supplier refuses RCA timelines:

- require "RCA within 30 days" plus interim findings within 10 business days.

I) Tier guidance (selection)

Critical (Tier 1): B1–B6 + E1 (if personal data) + F1 (if sub-processors) + G1 (if critical service)

Important (Tier 2): C1–C4 + E1 where applicable

Low (Tier 3): D1–D2 (plus E1 where applicable)